

NIST Cybersecurity Framework (CSF)

1. Overview

The NIST Cybersecurity Framework (CSF) is a **voluntary framework**, developed by the U.S. National Institute of Standards and Technology, providing a common language and structured approach for organizations to understand, manage, and reduce cybersecurity risk. Unlike the compliance frameworks covered earlier in this series (HIPAA, PCI DSS, SOX), NIST CSF is not a certification an organization obtains and is not tied to a specific industry or data type — it's a flexible, outcome-oriented framework applicable to essentially any organization, regardless of sector or size.

Property	Detail
Type	Voluntary framework (not a certifiable standard)
Maintained by	NIST (U.S. National Institute of Standards and Technology)
Current major version	CSF 2.0 (released 2024, updated from CSF 1.1)
Output	No certification — a self-assessed risk management structure and common vocabulary
Who uses it	Any organization voluntarily; often referenced by U.S. federal agencies, critical infrastructure sectors, and increasingly required or referenced contractually

2. Why NIST CSF Is Different From the Compliance Frameworks Already Covered

This is the most important distinction to establish upfront, directly extending the Compliance vs. Security guide's core theme: NIST CSF isn't something an organization "passes" or "fails," and there's no formal external certification body issuing a NIST CSF certificate the way there is for ISO 27001 or SOC 2. It is a **descriptive, organizing structure** — a common vocabulary and a way of thinking about cybersecurity risk holistically — that organizations adopt voluntarily to structure their own risk management program, often *alongside* a certifiable framework like ISO 27001, rather than instead of one.

3. The Six Core Functions (CSF 2.0)

CSF 2.0 organizes cybersecurity activities into six high-level functions — a meaningful change from CSF 1.1's five functions, with the addition of **Govern** reflecting an increased emphasis on cybersecurity as an organizational governance matter, not purely a technical/operational one.

Function	Purpose
Govern (GV)	Establish and monitor the organization's cybersecurity risk management strategy, expectations, and policy — the newest function in CSF 2.0, reflecting that effective security starts with organizational governance and accountability
Identify (ID)	Understand the organization's assets, systems, data, risks, and business context well enough to manage cybersecurity risk effectively
Protect (PR)	Implement appropriate safeguards to ensure delivery of critical services and limit or contain the impact of a potential security event
Detect (DE)	Implement activities to identify the occurrence of a cybersecurity event in a timely manner
Respond (RS)	Take action regarding a detected cybersecurity incident to contain its impact
Recover (RC)	Maintain plans for resilience and restore capabilities or services impaired by a cybersecurity incident

These six functions are not a strict sequence — an organization operates across all of them continuously and simultaneously, and the framework is explicitly designed to reflect an ongoing, cyclical process rather than a one-time linear project.

4. Categories and Subcategories

Each of the six functions is broken down further into **categories** (specific groups of outcomes, e.g., under Protect: "Identity Management, Authentication, and Access Control") and **subcategories** (specific, granular outcome statements, e.g., "Identities and credentials are issued, managed, verified, revoked, and audited"). This hierarchical structure — Function → Category → Subcategory — is what makes the framework usable as a practical assessment and gap-analysis tool, rather than staying at a purely conceptual level.

5. Implementation Tiers

NIST CSF describes an organization's cybersecurity risk management maturity using four **Implementation Tiers** — these describe the degree of rigor and sophistication in an organization's risk management practices, **not** a maturity scorecard for individual controls:

Tier	Characteristics
Tier 1: Partial	Risk management practices are informal, reactive, and often ad hoc; limited awareness of organizational cybersecurity risk
Tier 2: Risk Informed	Risk management practices are approved by management but may not be established as organization-wide policy; some awareness but inconsistent application
Tier 3: Repeatable	Formally approved, organization-wide risk management practices, regularly updated based on changing business requirements and threat landscape
Tier 4: Adaptive	The organization adapts its cybersecurity practices continuously based on lessons learned and predictive indicators, with risk management fully integrated into organizational culture

Tiers describe the organization's overall approach and rigor, not a per-control checklist — an organization doesn't need to reach Tier 4 across every category to be using the framework effectively; the appropriate tier depends on the organization's own risk tolerance and resources.

6. Profiles — Tailoring the Framework

A **Profile** represents the alignment of an organization's specific requirements, risk tolerance, and resources against the desired outcomes described by the Core Functions/Categories/Subcategories. Organizations typically develop:

- A **Current Profile** — describing outcomes currently being achieved.
- A **Target Profile** — describing the outcomes needed to achieve organizational risk management goals.

The gap between the Current and Target Profile drives a prioritized action plan — this Profile mechanism is what makes the framework genuinely adaptable to organizations of vastly different size, sector, and risk tolerance, rather than imposing one universal expectation on everyone identically.

7. Relationship to Other Frameworks

NIST CSF is frequently used as an **organizing overlay** on top of more prescriptive frameworks rather than a replacement for them:

- An organization might use NIST CSF's six functions to structure its overall risk management narrative and executive reporting, while implementing **CIS Controls** (see the companion guide) or **ISO 27001 Annex A** controls as the specific technical control set fulfilling each function's outcomes.
- NIST also separately publishes **NIST SP 800-53** (a much more detailed, prescriptive control catalog primarily used by U.S. federal agencies and federal contractors) — CSF and SP 800-53 are complementary, not competing: CSF provides the high-level risk management structure and vocabulary, while SP 800-53 provides exhaustive, specific control implementation detail.
- Many regulatory and contractual references (including some state-level U.S. breach notification safe-harbor provisions) explicitly point to NIST CSF adoption as evidence of reasonable cybersecurity practice.

8. Why Organizations Adopt NIST CSF

- **Common vocabulary** — provides a shared language for discussing cybersecurity risk across technical teams, executives, boards, and external partners who may not share deep technical backgrounds.
- **Flexibility** — applicable across virtually any sector or organization size, unlike frameworks scoped to a specific data type (HIPAA) or industry (PCI DSS).
- **Risk-based prioritization** — the Profile mechanism supports genuinely risk-informed prioritization rather than a one-size-fits-all checklist.
- **Regulatory and contractual recognition** — increasingly referenced by regulators, cyber insurance underwriters, and contract counterparties as an evidentiary baseline for "reasonable" cybersecurity practice, even without formal certification.

9. Common Real-World Adoption Gaps

- Treating CSF adoption as a documentation exercise (mapping existing practices to the framework's language) without genuinely using the Current/Target Profile gap analysis to drive real prioritization and resource allocation.

- Underinvesting in the newer **Govern** function specifically, since it requires genuine executive/board engagement rather than purely technical implementation.
- Assuming CSF adoption alone constitutes "compliance" with something, when — per Section 2 — there is no certification to actually achieve; organizations sometimes conflate CSF alignment with the assurance a certifiable framework like ISO 27001 or SOC 2 provides to external parties.
- Applying the framework only to a narrow technical security team's scope, missing the intended organization-wide governance and risk management integration the 2.0 revision specifically emphasizes.

10. Summary

NIST CSF is a voluntary, non-certifiable framework providing a common structure and vocabulary for managing cybersecurity risk, organized around six core functions (Govern, Identify, Protect, Detect, Respond, Recover), each broken into categories and subcategories, with Implementation Tiers describing organizational maturity and Profiles enabling risk-based tailoring to an organization's specific context. Its primary value lies in flexibility and communicability rather than prescriptive control detail — which is exactly why it's most often used as an organizing overlay alongside a more detailed, prescriptive control set (CIS Controls, ISO 27001 Annex A, or NIST SP 800-53) rather than as a standalone implementation guide on its own.